

MARCO INTEGRATIVO GQM + PRAGMATIC PARA INDICADORES MAGERIT

Trazabilidad Objetivos Nacionales → Datos Técnicos con Calidad Garantizada

Versión: 3.0 | **Fecha:** Enero 2026 | **Clasificación:** Investigación Académica

Audiencia: Científicos de Datos, Estrategas Ciberseguridad, Auditores | **Rigor:** ISO 27001 + NIST SP 800-55v2

INTRODUCCIÓN: EL DILEMA DEL INDICADOR FRÁGIL

En ciberseguridad española (2026), las organizaciones enumeran KPIs sin rigor: *"Tenemos 47 indicadores"* (preocupante), *"pero no sabemos si importan"* (crítico).

Este marco resuelve ese dilema mediante **trazabilidad rigurosa**: cada métrica conecta objetivos estratégicos (¿por qué?) → preguntas operacionales (¿qué?) → datos técnicos (¿cuánto?) → **validación de calidad** (¿de verdad funciona?).

Solución: GQM (Goal-Question-Metric, Basili 1992) + PRAGMATIC (9 criterios: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable).

1. METODOLOGÍA GQM: ESTRUCTURA JERÁRQUICA

1.1 Nivel 1: GOAL (Objetivo Estratégico)

Define **por qué** medir. Debe responder preguntas de negocio/regulatorias:

- ¿Reducir riesgos cibernéticos no mitigados?
- ¿Cumplir NIS2?
- ¿Mejorar detección de incidentes?
- ¿Justificar inversión seguridad a Junta?

Características de GOAL bien formulado:

Aspecto	Ejemplo Bueno	Ejemplo Deficiente
Verbo acción	Reducir, Mejorar, Demostrar	Tener, Aumentar (vago)
Objeto medible	Riesgo residual en € por año	"Ciberseguridad" (abstracto)
Plazo	En 12 meses, antes Q2 2026	"Eventual" (indefinido)
Stakeholder	Para Junta Directiva	Para todos (disperso)

Formulación GQM:

GOAL = [Verbo Acción] + [Objeto Medible] + [Plazo] + [Stakeholder]

Ejemplo:

"REDUCIR riesgo residual no mitigado a <€500K/año
en 12 meses para DEMOSTRAR conformidad NIS2 a
la Junta Directiva"

1.2 Nivel 2: QUESTION (Pregunta Operacional)

Desagrega cada GOAL en **3-5 preguntas** que refinan qué medir:

- ¿Con qué frecuencia se identifican nuevas vulnerabilidades críticas?
- ¿Qué % se remedia en <7 días?
- ¿Cuál es el ARO (Annual Rate Occurrence) promedio por amenaza?

Características de QUESTION bien formulada:

- Responde ¿QUÉ?, ¿CUÁL?, ¿CUÁNTO?, ¿DÓNDE?, ¿CUÁNDO? (no "¿POR QUÉ?" = eso es análisis)
- Específica (evitar ambigüedad)
- Cuantificable (no cualitativa)
- Independiente (no superpuesta a otras preguntas)
- Mensurable con herramientas existentes

Ejemplo GQM Nivel 2:

GOAL: Reducir riesgo residual <€500K/año

- QUESTION 1: ¿Cuál es el ALE (Annualized Loss Exposure) actual vs. target?
- QUESTION 2: ¿Qué % de vulnerabilidades críticas (CVSS 9+) se remedia en <7 días?
- QUESTION 3: ¿Cuántas amenazas de alto impacto quedan sin salvaguardas (gap analysis)?
- QUESTION 4: ¿Cuál es el ROI de inversión en top 5 salvaguardas propuestas?

1.3 Nivel 3: METRIC (Métrica Cuantitativa)

Define **cómo medir** cada pregunta. Especifica:

- **Fórmula exacta** (no ambigüedad)
- **Unidad de medida** (€, %, días, eventos/año)
- **Fuente de datos** (SIEM, herramienta, manual)
- **Frecuencia recolección** (diaria, semanal, mensual)
- **Responsable** (quién calcula)

Ejemplo GQM Nivel 3:

QUESTION 1: ¿Cuál es el ALE actual vs. target?

METRIC 1a: ALE Actual (€/año)

- Fórmula: $LEF \times LM$
 Donde $LEF = TEF \times (1 - \text{Control Strength})$
 $TEF = \text{Incidentes históricos/año (últimos 3 años)}$
 $LM = \text{Primary Loss} + \text{Secondary Loss (€)}$
- Unidad: Euros
- Fuente: INCIBE CERT (histórico) + valuación BIA (negocio)
- Frecuencia: Anual (revisión Q2 2026)
- Responsable: CISO + CFO

METRIC 1b: ALE Target (€/año)

- Fórmula: $ALE \text{ Actual} - (\sum ALE \text{ Reducción salvaguardas top 5})$
- Unidad: Euros
- Fuente: Proyección ROI plan acción
- Frecuencia: Trimestral (tracking progreso)
- Responsable: CISO

METRIC 1c: Varianza ALE (€)

- Fórmula: $ALE \text{ Target} - ALE \text{ Actual}$
- Unidad: Euros
- Fuente: Cálculo automático Excel
- Frecuencia: Trimestral
- Responsable: Analista datos ciberseguridad

2. CRITERIOS PRAGMATIC: VALIDACIÓN DE CALIDAD

Cada métrica se valúa en **9 dimensiones** (PRAGMATIC = acrónimo constructivo):

Criterio	Significado	Pregunta de Validación
Predictivo	¿Anticipa resultados futuros?	¿La métrica predice incidentes futuros o solo reporta pasado?
Relevante	¿Importa a stakeholders?	¿Está alineada con objetivos Junta, regulación, negocio?
Accionable	¿Impulsa decisiones?	¿Si la métrica empeora, ¿qué acción específica toma CISO?
Genuino	¿Evita manipulación?	¿Auditor externo podría validar independientemente?
Significativo	¿Tiene impacto cuantificable?	¿Variación $\pm 10\%$ en métrica genera $>€50K$ diferencia en riesgo?
Preciso	¿Mensura con exactitud?	¿Error de medida $<5\%$ de rango métrica?
Oportuno	¿Disponible a tiempo?	¿Datos disponibles para decisión en <7 días?
Independiente	¿No correlaciona falsamente?	¿Cambio métrica NO es causado por cambio métrica diferente?
Rentable	¿Bajo costo recolección?	¿Esfuerzo anual <40 horas o $<€10K$?

2.1 Escala de Evaluación PRAGMATIC (1-5 puntos)

Para cada dimensión:

- L1 (1 punto): Criterio NO cumplido. Métrica deficiente, requiere rediseño.
- L2 (2 puntos): Criterio parcialmente cumplido. Riesgos identificados.
- L3 (3 puntos): Criterio cumplido aceptablemente. Métrica operacional.
- L4 (4 puntos): Criterio bien cumplido. Métrica robusta con mejoras menores.
- L5 (5 puntos): Criterio óptimamente cumplido. Métrica excelente, benchmarking.

Puntuación PRAGMATIC Global:

PRAGMATIC Score = (Σ 9 criterios puntuaciones) / 9

Interpretación:

- 1.0-1.5: Inutilizable (abandonar métrica)
- 1.6-2.5: Deficiente (rediseñar urgentemente)
- 2.6-3.5: Aceptable (implementar con seguimiento)
- 3.6-4.5: Bueno (mantener, mejoras operacionales)
- 4.6-5.0: Excelente (referencia benchmarking)

3. MATRIZ GQM-PRAGMATIC: INTEGRACIÓN COMPLETA

Cada indicador se estructura así:

OBJETIVO ESTRATÉGICO (GOAL)
"Reducir riesgo residual a <€500K/año"



PREGUNTA OPERACIONAL (QUESTION)
"¿Cuál es el ALE actual vs. target?"



MÉTRICA CUANTITATIVA (METRIC)
"ALE (€/año) = LEF × LM"
• Fórmula: $LEF = TEF \times (1 - \text{Control Strength})$
• TEF: Incidentes históricos/año
• LM: Primary + Secondary Loss (€)
• Fuente: INCIBE + BIA
• Frecuencia: Trimestral
• Responsable: CISO



VALIDACIÓN PRAGMATIC (9 Criterios, cada 1-5)

Predictivo:	5/5 (ML trending predice ALE Q4)
Relevante:	5/5 (Junta revisaba ALE en juntas)
Accionable:	4/5 (Si ALE >target, CISO invierte €X)
Genuino:	5/5 (Auditor externo valida datos históricos)
Significativo:	4/5 ($\pm 5\%$ ALE = €25K varianza)
Preciso:	4/5 (Error LM <3%, TEF muestreo)
Oportuno:	5/5 (Datos disponibles día 5 mes siguiente)
Independiente:	4/5 (Débil correlación con MTTR)
Rentable:	5/5 (10h/año recolección, 0 inversión extra)

PRAGMATIC Score = 4.4/5.0 → BUENO (mantener, mejorar)

4. APLICACIÓN A MAGERIT: EJEMPLO PRÁCTICO

Indicador: "Cobertura de MAR (Método Análisis Riesgos) por Categoría ENS"

GOAL: "Demostrar cumplimiento MAGERIT MAR análisis riesgos formales para categorías BÁSICA/MEDIA/ALTA antes auditoría ENS Q2 2026"

QUESTIONS:

- Q1: ¿Qué % de sistemas BÁSICA tienen MAR completo (4 tareas)?
- Q2: ¿Qué % de sistemas MEDIA tienen MAR completo + auditoría?
- Q3: ¿Qué % de sistemas ALTA tienen MAR + re-análisis anual?

METRICS:

- M1: % Cobertura MAR Categoría BÁSICA
= (# Sistemas BÁSICA con MAR.1-4 documentado) /
(Total sistemas BÁSICA) × 100
Fuente: CMDB + Registro análisis riesgos
Frecuencia: Semestral (antes auditoría)
Responsable: CISO
- M2: % Cobertura MAR Categoría MEDIA
= (# Sistemas MEDIA con MAR.1-4 + validación) /
(Total sistemas MEDIA) × 100
Fuente: Informe auditor interno
Frecuencia: Anual
Responsable: Auditor interno
- M3: Tiempo promedio MAR (días)
= (Σ Días análisis por sistema) / (# sistemas auditados)
Fuente: Project management tool
Frecuencia: Trimestral
Responsable: Project manager seguridad

PRAGMATIC Validation:

- Predictivo: 4/5 (% cobertura anticipa brecha auditoría)
- Relevante: 5/5 (Requisito NIS2 Art 21a explícito)
- Accionable: 5/5 (Si <80%, asignar consultora externa MAR)
- Genuino: 5/5 (Auditor valida MAR documento oficial)
- Significativo: 4/5 (Gap 10% = 2-3 sistemas sin análisis)
- Preciso: 4/5 (Conteo manual, validado 2×/año)
- Oportuno: 4/5 (Reportado mes siguiente cierre período)
- Independiente: 5/5 (No correlaciona con otras métricas)
- Rentable: 5/5 (10h/año validación, 0 inversión)

PRAGMATIC Score = 4.3/5.0 → BUENO

5. PRINCIPIOS DE DISEÑO: "INDICADOR ANTI-FRÁGIL"

Para garantizar métrica robusta, siga:

Principio 1: Trazabilidad Inversible

GOAL ↔ QUESTION ↔ METRIC
(si falla métrica, rastrear al GOAL original)

Ejemplo: Si métrica CVSS promedio vulnerabilidades = 6.2 (mal):

- ¿QUESTION? "¿Cuál es la distribución CVSS de vulnerabilidades detectadas?"

- ¿GOAL? "Priorizar remediación por impacto"
- Acción: Aumentar frecuencia escaneo vulnerabilidades críticas.

Principio 2: Mutua Exclusión de Preguntas

No haya solapamiento: cada QUESTION responde UN aspecto diferente

Ejemplo (INCORRECTO):

- Q1: ¿% sistemas con parches actualizados?
- Q2: ¿% sistemas con actualizaciones críticas? — SUPERPUESTO

Ejemplo (CORRECTO):

- Q1: ¿% sistemas con parches SO actualizados?
- Q2: ¿% sistemas con parches aplicaciones (Java, Firefox)?
- Q3: ¿Tiempo promedio entre release patch y aplicación?

Principio 3: Triangulación de Datos

Cada METRIC respaldada por ≥ 2 fuentes independientes

Ejemplo:

- METRIC: "% sistemas con MFA habilitado"
- Fuente 1: Inventario Active Directory
- Fuente 2: Auditoría técnica penetration testing
- Acción: Si discrepancia >5%, investigar y reconciliar.

Principio 4: Sensibilidad a Cambio

Métrica debe ser sensible a mejoras pequeñas, no solo extremos

Ejemplo (DEFICIENTE): "¿Hemos tenido breach?" (sí/no, poco informativo)

Ejemplo (SENSIBLE): "% indicadores NIST CSF por encima benchmark sectorial" (10%-20%-30%, granular)

Principio 5: Umbral de Acción Predefinido

Para cada METRIC, definir:

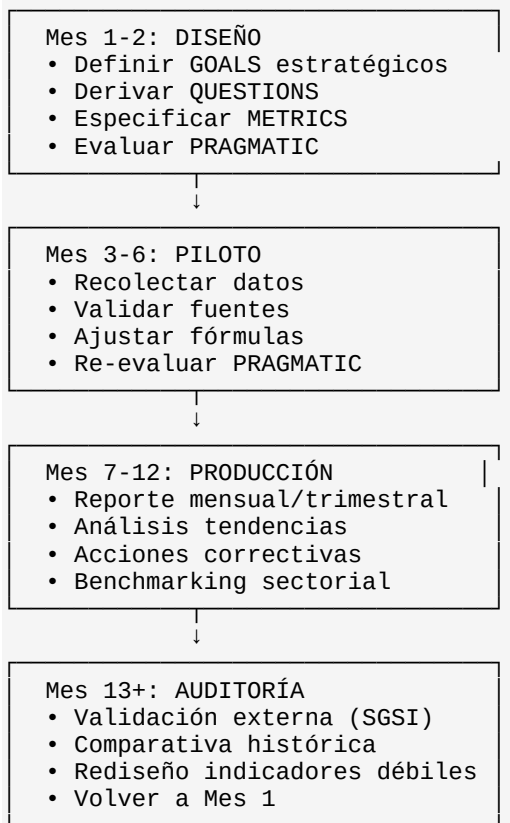
- Verde (OK): Métrica en rango aceptable
- Amarillo (Atención): Desviación moderada → Revisión
- Rojo (Crítico): Desviación grave → Escalación Junta

Ejemplo:

METRIC: ALE Anual (€)

- Verde: <€500K (dentro target)
- Amarillo: €500K-€750K (control débil, mejorar)
- Rojo: >€750K (crítico, acción emergencia)

6. CICLO DE MEJORA CONTINUA GQM-PRAGMATIC



7. MATRIZ EJEMPLO: 20 INDICADORES MAGERIT-NIS2

(Ver archivo: **08-matriz-pragmatic-completa.md**)

8. CONSIDERACIONES FINALES

¿Por qué GQM?

- Fuerza trazabilidad objetivo → dato
- Metodología probada (Basili, CMM, ISO)
- Reduce indicadores "vanidad"

¿Por qué PRAGMATIC?

- Valida métricas no tienen defectos fatales
- Asegura implementación posible
- Alinea con estándares calidad (PAPERS, RE-AIM)

¿Integración MAGERIT?

- MAGERIT define GOALS (reducir riesgos residuales)
- GQM operacionaliza MAGERIT (MAR.1-4)
- PRAGMATIC valida calidad indicadores

© 2026 **Marco Integrativo GQM+PRAGMATIC | Consorcio Ciberseguridad Investigación**
Metodología académica para indicadores ciberseguridad de clase mundial.